KAIROS: Transactional Security Enforcement at the System Boundary for LLM Agents

Kristoffer Hempel[1] Nils Loose[1,2] Lorenzo Cavallaro[2,3] Thomas Eisenbarth[1]
[1]Universität zu Lübeck [2]University College London [3]Mohamed bin Zayed University of Artificial Intelligence

arXiv:2610.18457v1 [cs.CR] 13 Oct 2026

***Abstract*—Large language model (LLM) agents are becoming an integral part of the software development lifecycle, and the capabilities granted to them allow an agent to act with the user's authority on any resource it can access. The reach that gives an agent its utility is equally available to an attacker who can steer it. Anything an agent ingests can carry an injected instruction, and since the model does not reliably distinguish instructions from data, indirect prompt injection should be mitigated by mediating the effects the agent produces. Such mediation faces a structural difficulty. Legitimate work and the first step of an attack often look alike when an individual action is observed, and what separates them lies later in the trace, so a monitor limited to allow and deny is forced to decide before the evidence accumulates. We present KAIROS, a reference monitor at the isolation boundary of an unmodified, opaque agent, where a tool call, a shell command, and a script the agent writes all cross the boundary as the same file and network operations, so that confinement holds regardless of the agent's behavior. A declarative policy that states which sources are trusted decides most effects deterministically and defers the rest, which are held while the agent continues speculatively. A decision oracle with bounded authority, such as a language model or a human, releases or refuses each deferred effect on the trace. Across three benchmarks and three agent models, KAIROS outperforms existing defenses in the trade-off between attack success and utility. In particular, on AgentDojo, it reduces attack success from 47.0% to 2.7% while its benign utility stays at the level of the undefended agent.**

***Index Terms*—LLM Agent security, indirect prompt injection, reference monitor, sandboxing, transactional rollback**

I. INTRODUCTION

LLM agents are increasingly deployed to act autonomously on behalf of users and organizations, operating on code bases, infrastructure, and communication channels over tasks that run for hundreds of steps without review [1], [2]. Their value hinges on the breadth of their access: to be useful, an agent reads broadly, executes code on the host, and reaches the network, all with the authority of the principal. Coding agents are the most prominent example, as they are routinely handed a repository, a shell, and network access. With this authority, an agent's effects reach far beyond its principal, through the code it commits, the packages it publishes, and the requests it sends. Recent incidents show that agents can compromise infrastructure far outside their task [3], [4].

This broad set of capabilities and access offers an unprecedented attack surface as everything the agent, and consequently the model, ingests enters the same context as the user's instructions without any systematic differentiation between control and (untrusted) data content [5]. This leaves the agent fundamentally vulnerable to indirect prompt injections [6] from an attacker who controls any part of the ingested content. As these agentic systems have already seen widespread public adoption despite the unprotected attack surface, recent attacks highlight the risk that unprotected deployment brings [7]. Repository content ingested by a coding assistant has been used to exfiltrate private SSH keys [8], inbound channels such as calendar invites have been used to steer assistant systems against the user's intent [9], and memory files used by agentic systems have been used to enable attack persistence [10]. Several of these attacks required no software vulnerability and used only the permissions the agent had legitimately been granted [10]. A public adaptive-injection challenge further showed that participants defeat deployed defenses given the opportunity to iterate [11].

Existing defenses against prompt injection commonly operate at the level of the prompt, the model, or the agent framework [12]–[16], and treat the environment in which the agent executes as given. Prompt- and model-level defenses make it less likely that the agent follows injected instructions, but provide no structural guarantee that it does not [12], [13], [17]. Framework-level defenses provide stronger, structural guarantees by enforcing policies on the agent's actions, but require a custom or modified harness [14]–[16], [18]. This excludes closed-source agents, and any guarantee has to be re-established whenever the agent is updated. They also mediate only relative to a declared interface, such as the agent's set of tools, so that complete mediation, the first requirement of a reference monitor [19], becomes an assumption about the deployment rather than a property of the mechanism [20]. A script the agent writes and runs remains outside their reach. Only a few approaches monitor agents at the operating-system level, and these either observe their actions [21] or block and terminate them as they occur [22], [23]. At the same time, agents are increasingly executed in sandboxes and virtual machines [24]–[26]. Such isolation is necessary to mediate every effect regardless of how the agent produces it, but it is not sufficient. An injected agent acts as a confused deputy [27] that stays within the authority it was granted while violating the intent of its task.

Isolation determines where an agent's effects can be stopped, but not which ones should be. Following the example in Fig. 1, an agent is, while setting up a repository, prompted by external content to set up a pre-commit hook. The policy cannot vouch for this write, as it stems from untrusted content, yet it also cannot refuse it without broadly harming utility. Refusing it breaks legitimate setups, while releasing it leaves

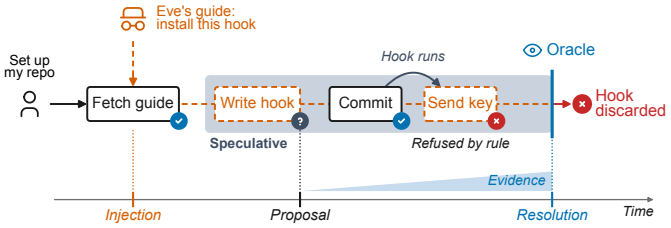

Fig. 1. Deferral in KAIROS. Eve's guide injects a hook the policy cannot vouch for, so the write is deferred. The agent continues, its commit runs the hook, and the hook's attempt to exfiltrate Alice's key is refused by the policy. On this evidence, the oracle discards the hook.

a planted hook in the repository, even if the malicious action is later detected. What separates the two cases appears only once the hook runs, and a monitor that must decide each effect on arrival cannot wait for it [28]. The monitor must therefore be able to defer and hold the write [29], letting the agent continue speculatively on a staged state [30]. This allows the decision to be postponed until the consequences are visible, yet before anything becomes irreversible.

We present KAIROS, a reference monitor at the isolation boundary of an unmodified, opaque agent. Because the monitor sits at this boundary, every effect of the agent crosses the monitor as the same kind of event, whether it stems from a tool call or from a script the agent wrote. This design guarantees confinement against a fully compromised agent, whatever the cause of its misbehavior. Since every effect crosses the monitor before it is released, the boundary also yields a complete record of the agent's effects and a point at which a human can intervene. By tracking provenance at the boundary and recording a trace of the agent's effects, the monitor enables authorization of each effect against the agent's previous steps. Combining a declarative policy with an external decision oracle lets the monitor decide effects the policy covers as they occur and defer the remaining ones to the point of irreversibility.

We implement KAIROS by running agents in a microVM managed by Cloud Hypervisor [31]. To enable deferral, file effects are staged in an overlay layer [32] and exported through FUSE [33], while network effects pass through a TLS-terminating proxy [34] that stalls requests until they are resolved. Mediation adds about 1.9 ms per file operation and 1.2 ms per request, negligible next to model inference. The decision oracle is a language model by default, following existing defenses that check an agent's actions against its task [17], and can be replaced by a human reviewer or a policy engine.

Across three benchmarks and three agent models, KAIROS outperforms existing defenses by achieving the highest net resilient performance [35], which equally weights attack success and utility. On AgentDojo [36], KAIROS reduces attack success from 47.0% to 2.7% while benign utility stays at the level of the undefended agent (85.1% against 82.7%). The framework-level defenses we compare against either reach slightly lower attack success at less than half the utility, or trail KAIROS on both. A strict configuration that refuses whatever the policy cannot vouch for leaves attack success unchanged within run-to-run noise but completes only 42.7% of benign tasks, so deferral and the oracle together recover the utility at no measurable cost in security. This holds on open-ended tasks, on which defenses that fix their plan in advance complete almost no work, and against an adaptive attacker that rewrites its injections against KAIROS.

In summary, we make the following contributions:

- KAIROS, a reference monitor for unmodified, opaque agents that guarantees confinement at their isolation boundary and defers the effects it cannot authorize, holding them while the agent continues speculatively until a decision oracle decides them (Sections II and III).
- An implementation for coding agents that requires neither modification of nor cooperation from the agent, holding file and network effects at a microVM boundary with about two milliseconds of overhead per mediated operation (Section III-D).
- A comprehensive evaluation across three benchmarks, three agent models, and an adaptive attacker, in which KAIROS achieves the best trade-off between security and utility (Section IV).

II. PROBLEM AND THREAT MODEL

Building on the challenges for securing agents described in Section I, we specify the setting and assumptions of this work. We consider an unmodified and opaque agent that may execute arbitrary code and use the system tools available within its environment. This requires a monitor outside the agent's reach [19]. However, isolation alone is not sufficient, as it only constrains where the agent's effects reach but not what the agent does with the access it is granted. An agent following injected instructions acts as a confused deputy [27]: it serves the malicious actor while staying within the authority granted by the sandbox. We therefore separate two properties.

Together with a monitor at its boundary, isolation provides *confinement*, ensuring that the agent's effects leave the environment only through the monitor and only once the monitor releases them. *Authorization* then decides which effects to release (Fig. 2).

A. Attacker Model

We consider an attacker who controls content the agent ingests while working on its task, such as a fetched web page, a file in a cloned repository, or an incoming message, and who uses it for indirect prompt injection. The attacker's goal is an effect that the agent performs with its own privileges on the attacker's behalf: exfiltration of sensitive data, injection of untrusted values into trusted arguments, state changes without a trusted request, or persistence that affects later sessions. We distinguish two trusted roles: the *principal*, who issues the task, and the *operator*, who deploys the monitor and writes its policy. While we focus on indirect injections here, assuming the operator and principal (Fig. 2) coincide, direct injections can also be considered when separating the two

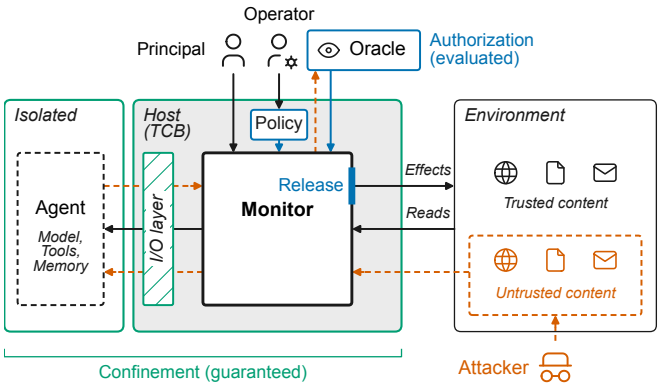

Fig. 2. Threat model overview.

roles. The attacker is adaptive and knows the design, the operator's policy, and the oracle. They may control every input the operator has not declared trusted, but not the agent or its model directly. The principal and their task, the operator and their policy, the host with its isolation layer, and the monitor are outside the reach of the attacker (Section II-B). We do not consider escape from the isolation layer, covert channels [37], or availability. Neither do we consider harm achieved by the agent's response text alone.

B. Confinement

The agent's components, such as its model, its tools, its memory, and the processes it spawns, are viewed as a unit inside the *isolation boundary*. Every outside effect the agent emits has to cross a small, fixed set of `I/O` channels (e.g., file, network, and control), which together form the `I/O` layer of this boundary. This separation makes the monitor oblivious to whether an effect is caused by a tool call, a script, or otherwise. The sequence of effects crossing these channels defines the agent's action trace. The confinement rests on three assumptions. First, we assume that the mediated channels are the only channels to the outside environment. Second, to enable the execution of agents running frontier models, we treat the channel to the model provider as an internal channel and assume that the model provider does not collude with the attacker. This assumption can trivially be lifted when using models run inside the isolated environment. Lastly, we assume that the host and monitor are trusted and correct entities. Together, these assumptions define the Trusted Computing Base (TCB) as the isolation layer, the monitor and the host, which, as a reference monitor, must be tamper-proof, always invoked, and small enough to be validated [19] (Section III). Everything outside the TCB, including the agent and its model, is untrusted. We therefore assume that the agent may be fully adversarial: it may issue arbitrary operations on any of the channels, including attempts to mislead the monitor about the purpose of an effect. Confinement provides three guarantees that hold regardless of the agent's behavior and of how the monitor decides:

(I) Every effect that leaves the isolated environment passes the monitor.
(II) No effect becomes irreversible before the monitor releases it.
(III) An effect refused by the monitor never becomes externally observable.

C. Authorization

The above guarantees ensure that the monitor controls every effect, but not that it releases the right ones. Determining which effects are admissible requires a reference for intent. The operator states what is trusted in a policy, which declares the trusted sources, the data that is sensitive, and the destinations that may receive it. The operator writes the policy, and the monitor releases an effect directly when its values stem from trusted sources and its data is cleared for the destination. However, the principal's intent is inherently semantic and can rarely be fully specified in advance [20]. Decisions that are not admissible through policy alone are therefore deferred to a *decision oracle*, which evaluates them against the principal's task as the description of their intent. The oracle is trusted to be benign, but not to be correct, as its decisions cannot generally be validated. Critically, since the oracle reads untrusted content, it is itself a target of prompt injection. It is therefore not part of the TCB on which confinement rests, and its authority is bounded, as it decides only the effects the policy defers. When the oracle refuses every deferred effect, the monitor reduces to a strict monitor that releases only what the policy admits. To have an unauthorized effect released, the attacker must therefore either make it appear to stem from trusted sources, or persuade the oracle to release it.

Tracking the provenance of data that flows through the agentic system provides a key challenge, as a monitor at the boundary cannot trace a value through an opaque agent that deliberately encodes it, much as taint tracking cannot follow implicit flows [38]. We therefore assume that the agent follows injected instructions fully, but does not deliberately transform values to hide their origin. An agent that does transform values is considered the fully adversarial agent of Section II-B, against which only confinement holds. The goal of authorization is that no *unauthorized* effect is released, i.e., no effect that carries a value not stemming from a trusted source (integrity) or data not cleared for its destination (confidentiality). Unlike confinement, this goal is not guaranteed, as it depends on the assumptions above and on the oracle's decisions. We therefore evaluate it, including what trusting the oracle costs in security compared to a strict monitor (Section IV). Attacks that persuade the oracle to release a deferred effect are within scope, and our evaluation covers an adaptive attacker (Section IV-B).

III. Design

The threat model (Section II) defines what the monitor must provide: confinement and authorization. This section describes the design of Kairos, which separates the two properties as mechanism and policy [39]. Confinement is the mechanism

by which every effect of the agent reaches the monitor, which can act upon it, while authorization is the policy that defines how to act. The central design choice informing the design of KAIROS is that the monitor does not have to act when an effect is proposed, but only before it becomes irreversible. We first define the agent's effects and trace (Section III-A), then the mechanism that confines and holds effects (Section III-B), and finally the decision procedure over it (Section III-C).

A. System Model

Given the position of the monitor outside of the agent, it can only observe events that cross the `I/O` layer. Consequently, any action taken by the agent is modelled by what crosses one of the `I/O` channels $ch \in C$. We consider three classes that each have a channel through the monitor: the mediated *state*, other *parties*, and the *principal*. The mediated *state* exists beyond the lifetime of the session and is commonly associated with the principal (e.g., the principal's working directory). The second class consists of other *parties* beyond the boundary, so an effect on them is generally irreversible once sent. We consider the *principal*, who issues the task and receives the result, to be a special party that interacts through the control channel. The agent's own ephemeral state, such as temporary files inside the environment, is part of the agent and not mediated. In our isolation layer, these classes are realized by the channels $C = \{\mathsf{file}, \mathsf{net}, \mathsf{ctrl}\}$ (Section III-D). This follows the design of runtime monitors as observers of an executor's actions [28]. Formally, we consider any operation op that passes the monitor through one of the channels $ch \in C$ to be an event:

$$e = (ch, dir, op, obj, v). \tag{1}$$

The direction $dir \in \{\mathsf{out}, \mathsf{in}\}$ differentiates inbound and outbound traffic, obj defines the outside source or target of the event (i.e., a path, a destination, or the principal) and v denotes the content of the operation. An event is oblivious to the action that initiated it. A tool call, an executed script, or a system operation are all represented as events over the channel ch. The temporally ordered sequence of events observed at the monitor forms the *agent trace*:

$$\sigma = e_1 e_2 \cdots e_n. \tag{2}$$

Not every event is visible outside the isolated environment. We call an outgoing event an *effect* if its release makes it externally observable, such as a file write, an unlink, or a network request. The sequence of externally observable behavior $obs(\sigma)$ is ordered by the time at which the monitor releases each effect [40]. Since the monitor may release an effect later than it was proposed, this order can differ from that of σ, and all guarantees below are stated over $obs(\sigma)$. An effect becomes irreversible at the moment it enters $obs(\sigma)$. For each effect e_i, the monitor decides $\delta(\sigma_{i-1}, e_i) \in \{\text{RELEASE}, \text{REFUSE}, \text{DEFER}\}$, that is, on the entire trace observed so far rather than on the effect alone. The guarantees of Section II-B follow, as every effect in $obs(\sigma)$ was decided by δ (I), an effect enters $obs(\sigma)$ only after it is released (II), and an effect that is not released never enters $obs(\sigma)$ (III).

B. Confinement: Mediation and Holding

Mediation. The monitor sits on the host at the `I/O` layer and is invoked on every event in both directions. Outgoing events are mediated and incoming events are tracked for provenance (Section III-C). Since the isolation layer exposes no other channel, coverage does not depend on the interface through which the agent acts, unlike monitors at the tool-dispatch layer, which see only the actions an agent declares. The monitor functions as a reference monitor [19] that is always invoked on all channels, providing guarantee (I). Additionally, it is tamper-proof and small by the assumptions of Section II-B. A monitor that can only release or refuse must decide immediately when an effect is proposed, and can therefore only enforce safety properties, whose violations are determined by the trace up to that point [28]. Whether an effect is authorized, however, often depends on provenance the monitor can only approximate and on intent it cannot specify in advance (Section II), so a binary monitor must err towards refusing legitimate work or releasing attacks. We therefore move the decision from the moment an effect is proposed to the moment it would become irreversible, following the principle that an irreversible decision under uncertainty should be postponed as long as the option is free to keep [41]. Likewise, a system that must remain recoverable holds its externally visible output until the state that produced it is committed [40], [42]. Validating at commit rather than blocking at proposal is also the cheaper choice when violations are rare [43], which is arguably the case for agents that mostly follow the intent of the principal. Formally, this turns the monitor from one that can only allow or truncate an execution into one that can also suppress an effect and insert it later, strictly enforcing more properties [29].

Holding. Concretely, RELEASE emits an effect, REFUSE suppresses it permanently and informs the agent, and DEFER suppresses it provisionally until it is later released or refused. Holding an effect requires keeping it out of $obs(\sigma)$ while the agent continues, and how this is realized depends on the target of the event. An effect on mediated state through the file channel can be *staged* by applying it to a copy visible only to the agent. An effect on an outside party becomes irreversible as soon as it is sent. If the response is not immediately required by the agent, such as a request that only reports success, the effect can be *stalled* at the boundary while the agent continues on a stand-in result, a *stub* that replaces the incoming event $res(e)$ that would have answered it. An effect whose actual result the agent needs, such as a request that fetches content, is *blocking* and must be decided before it is sent. Effects on state are thus stageable, effects on parties stallable or blocking depending on whether the agent needs the response, and exchanges with the principal are not held, as the agent's response is text whose harm lies outside our scope (Section II). The isolation layer must therefore provide a staging area for the state the monitor mediates, such as a

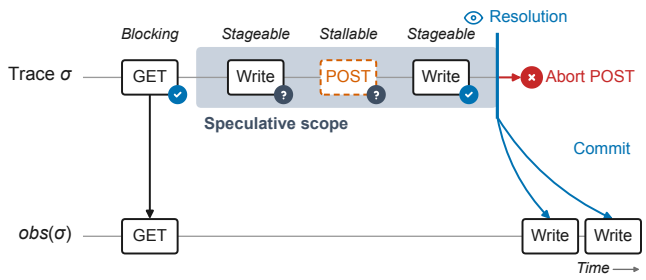

Fig. 3. Speculative execution example. Badges mark the policy's decision per effect (a check for release, a question mark for defer). From the first deferral on, effects are held in a speculative scope until the oracle resolves it.

copy-on-write view that can later be applied or discarded, and a way to hold outgoing requests at the boundary. Section III-D describes how our channels provide both.

Speculative execution. Once an effect is deferred, the agent continues in *speculative execution*, running ahead on state that may later be discarded [30]. What it does next may build on a stub or on staged state, so the effects that follow form a *speculative scope* that is held and resolved together. A speculative scope must be resolved before any held effect, or any content derived from a stub, would enter $obs(\sigma)$. Releasing a held effect *commits* it. Its staged state is applied or its held request is sent, and the labels admitted within its scope become permanent (Section III-C). Refusing a held effect *aborts* it, and its staged state, held request, and labels are discarded. An example of speculative execution is shown in Fig. 3. Exploring an effect speculatively and abandoning it is, from outside, indistinguishable from never having proposed it. This does not extend to the agent, as its context is not rolled back and may still contain a stub for an effect that never happened. Rolling the agent back instead would require access to its context, which an unmodified, opaque agent does not offer. The monitor must therefore tell the agent when a held effect is refused, so that it does not continue as if the effect had taken place.

C. Authorization: Labels, Policy, and Oracle

The reference monitor introduced in Section III-B provides the capabilities to decide every effect, but does not specify how the decision is made. We first discuss the labels we consider and their propagation before discussing the policy- and oracle-based decision procedures.

Labels. Following Section II, authorization judges an effect by two labels, *integrity* and *confidentiality*. Integrity determines whether the values an effect carries stem from a trusted source, and confidentiality determines whether the data it carries is allowed to reach its destination. We represent both as lattices [44], integrity as untrusted $\sqsubseteq$ trusted and confidentiality as sensitivity levels ordered from public to critical. When values are combined, their labels merge towards the conservative element, finding the greatest lower bound (meet) for integrity and the least upper bound (join) for confidentiality. Concretely, combining a trusted with an untrusted value yields an untrusted one, while combining public with sensitive data carries the sensitive label. The initial labels are assigned by the policy, which must be specified *a priori*. The policy declares locations of the mediated state and specific parties as trusted sources. It assigns sensitivity levels to the locations and parties whose data is sensitive, and to each party a clearance. Whether the principal's task is a trusted source is likewise a declaration of the policy. All other content is considered untrusted and public.

Provenance. Determining whether an effect is authorized thus depends on the *provenance* of its values. The monitor, however, sees values only where they cross the boundary, i.e., the content the agent reads and the effects it emits, but not how one turns into the other. Labels therefore enter with incoming events which carry the label of their source. To build provenance, the monitor keeps a record of what the agent has read. T_i collects the values the agent has received from trusted sources up to event e_i, starting from the values the policy itself declares, and S_i collects the sensitive values it has received. For an incoming event e_i from a trusted source, $T_i = T_{i-1} \cup \{v_i\}$, where v_i is its content, and S_i grows likewise. T_i is thus the set of values the agent could have obtained legitimately. Hence, a value in an effect that stems from T_i is justified by a trusted source, and any other value is not. Both sets grow only with incoming events, and nothing the agent emits can add to T_i, as the agent's own output is exactly what the monitor cannot trust. Since values pass through the agent's model and private state, which the monitor cannot observe, labels have to be re-established at the boundary. A value x in an effect is trusted only if it is *derivable* from T_i: $D(x, T_i)$. Sensitivity is checked in the opposite direction, since a missed match has opposite consequences on the two axes, as a value that is not recognized as trusted is deferred, whereas sensitive data that is not recognized would be released. An effect therefore carries sensitive data if a value of S_i occurs anywhere in it, such as a private key embedded in a URL. We require D to be sound against the injected agent of Section II, which does not deliberately transform or otherwise mask values. Tracking individual values through the inference of a language model remains an open problem, and approaches that avoid this assumption propagate labels coarsely through the agent's context instead [14], [15], which requires modifying the agent and taints much of what it emits (Section V). For the same reason, we also require that a location the agent writes inherits the merged labels of everything the agent read before the write, so that state cannot launder labels between effects or across sessions. Within a speculative scope, labels admitted by held effects stay local to the scope and become permanent only when they are committed (Section III-B).

Policy. When the monitor has to decide on an effect, it first consults the policy before relying on the oracle. The policy answers three questions in order. *First, does an explicit rule of the operator forbid the effect?* If so, such as for deleting

a repository's history, the effect is refused. *Second, do the values that steer the effect stem from a trusted source?* Not every value of an effect needs to be trusted: a summary of an e-mail legitimately contains the e-mail's text. Only the values that steer the effect, such as its destination, its recipient, or the command it runs, must do so. We write $G(e)$ for these *gated* values and require $D(x, T_{i-1})$ for every $x \in G(e_i)$. *Third, is the data the effect carries cleared for its target?* With $\ell(e)$ the join of the sensitivity levels of the values of S_{i-1} that occur in e, and $clr(obj(e))$ the clearance of its target, we require $\ell(e_i) \sqsubseteq clr(obj(e_i))$. Locations of the mediated state carry the highest clearance, since data written there does not leave it and keeps its label. If both checks hold, the policy *vouches* for the effect, and otherwise it defers the effect to the oracle:

$$\delta(\sigma_{i-1}, e_i) = \begin{cases} \text{REFUSE} & \text{if a rule of the policy forbids } e_i, \\ \text{RELEASE} & \text{if the policy vouches for } e_i, \\ \text{DEFER} & \text{otherwise.} \end{cases} \tag{3}$$

For example, a request to an address named in the task that carries only public data is released, while the same request to an address found in an e-mail is deferred. For a blocking effect, deferral cannot hold the effect, so the oracle decides it before it is sent.

Oracle. Deferred effects are decided by the *decision oracle*. The decision oracle can be the operator, another policy engine, or another model instance as in our evaluation (Section III-D). The oracle receives a *view* the monitor curates, consisting of the principal's task and the policy, the deferred effects with the provenance of their values, the trace that led to them, and the untrusted content they build on as evidence, and it returns a decision for each deferred effect:

$$O\big(view(\sigma)\big) : def(\sigma) \to \{\text{RELEASE}, \text{REFUSE}\}, \tag{4}$$

where $def(\sigma)$ are the effects δ deferred, each accompanied by a justification that serves as the notice to the agent and the record of the decision. The oracle's authority is bounded by construction as every effect in $obs(\sigma)$ was either released by δ or deferred by δ and released by O, so the oracle can release only what the policy deferred and can never override a refusal. It is therefore the only point at which an untrusted value can reach a released effect or sensitive data an uncleared destination. Hence the oracle represents the point of endorsement and declassification [45], [46]. An oracle that refuses every deferred effect reduces the monitor to the strict monitor of Section II, and any other oracle can only add releases. Since its view contains untrusted content, the oracle is itself a target of the attacker (see Section V for a discussion on the impact of the bandwidth of this channel).

D. Implementation

Isolation and channels. The agent operates within a Cloud Hypervisor [31] microVM, which provides a hardware-enforced boundary without a shared kernel. The working directory constitutes the mediated state and is exported to the guest via the file channel. The guest's root filesystem, containing the

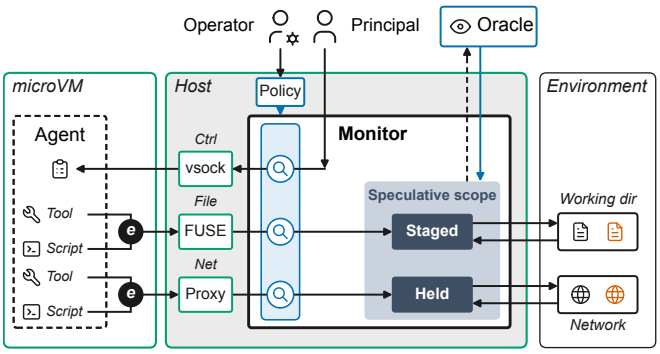

Fig. 4. Overview of KAIROS.

agent's tool installations and credentials, remains outside the scope of mediation. The file channel mounts the working directory as the read-only lower layer of an OverlayFS [32], and all modifications go to a separate upper layer, so the working directory stays unchanged and the upper layer holds exactly the staged state. The merged view of both layers is re-exported to the guest using a FUSE passthrough [33] and virtio-fs, ensuring that all file operations are executed by a user-space process on the host. The net channel functions as a transparent TLS-terminating proxy implemented with mitmproxy [34]. A firewall rule redirects all outbound traffic to the proxy, and the proxy's certificate authority is embedded within the guest image. Terminating TLS at the proxy separates mediation from the agent's TLS library, unlike eBPF hooks, which depend on specific TLS implementations [21]. File writes and unlinks are stageable, requests with state-changing methods stallable, and `GET` requests blocking, as we assume the agent requires their response. Traffic directed to the model provider is decrypted, logged, and released, as the provider is considered an internal channel (Section II-B). The ctrl channel is the agent's terminal over vsock, through which the task arrives as the agent's start command and the response returns to the principal. Since these channels are the only paths to the working directory, the network, and the principal, every effect crosses the monitor (I), and a tool call and a script the agent wrote reach it as the same event (Fig. 4).

Holding. The upper layer of the overlay holds the writes of the open speculative scope, and a write-ahead log records a pre-image of each change, so that the scope can be rolled back. Committing the scope merges its changes into the working directory, and aborting it discards them. A held request is stalled at the proxy while the agent continues on a stub that replaces $res(e)$, and it is sent only when the scope commits. The prototype keeps one speculative scope open at a time, as OverlayFS offers only a single writable upper layer per mount. A further effect that would need holding therefore forces the open scope to resolve first, as does a state-changing request, content derived from a stub that is about to leave the boundary, or the end of the task. When a held effect is refused, the agent receives an abort notice specifying the withheld

effects, affirming that the remainder of the task continues, instructing the agent to proceed, and permitting re-issuance only for effects explicitly required by the task.

Policy and provenance. The policy is defined as a short file that declares the trusted and sensitive sources and the parties with their clearances, together with a small layer of rules. Parties the policy does not name are deferred in all configurations. Following Section III-C, provenance is re-established at the boundary by matching values. We instantiate derivability as equality up to normalization,

$$D(x, T_i) \iff \exists\, t \in T_i : norm(x) = norm(t), \qquad (5)$$

where $norm$ lowercases a value and removes its whitespace. T_0 holds the values extracted from the principal's task, and each result from a declared trusted source adds its values. For sensitivity, S_i holds the tokens of the content read from sensitive sources, and an effect carries a sensitive value if one of these tokens occurs in it after normalization, which over-approximates towards deferral. Matching misses values the agent transforms, and it cannot tell an attacker's value from an identical trusted one. We discuss both limits in Section V.

Decision oracles. The oracle O is invoked once per resolution of a speculative scope and, for a blocking request that the policy defers, before the request is sent. Its view (Section III-C) presents the trace with untrusted content marked as data and adds the lines of earlier content that mention the values of the deferred effects. The provenance of each value is stated as its origin, such as *supplied by read_file:bill.txt, not by the user's message*, rather than as a label, since a language model reads a label such as *untrusted* as a verdict. In our evaluation, this view is given to a separate language model instance without tools, queried at temperature zero, whose model is configured independently of the agent's. Output that cannot be parsed and failed calls count as REFUSE, so a failing oracle can only refuse.

IV. Evaluation

We compare KAIROS against existing defenses across three benchmarks and three agent models, and analyse the contribution of its components and evaluate the overhead KAIROS introduces. The evaluation is structured along four questions. Section IV-B asks whether KAIROS stops injection attacks while preserving utility, compared to prompt-, model-, and framework-level defenses. Section IV-C examines how much the policy decides on its own and what reaches the oracle. Section IV-D isolates what deferral and the oracle contribute, and which model choices drive security and utility. Section IV-E quantifies what KAIROS adds in tokens, model calls, and latency.

A. Setup

Benchmarks. We evaluate on AgentDojo [36], the standard benchmark for indirect prompt injection, and on two extensions: AgentDyn [47], whose legitimate actions are not known in advance, and AutoDojo [48], whose attacker adapts its injections to the defense.

AgentDojo simulates four application suites with 97 user tasks and 629 injection cases. Each injection places the attacker's goal into content the agent reads while completing a user task. We use its `important_instructions` attack, against which CaMeL [14] and Progent [16] also report their results. *AgentDyn* contains 60 open-ended tasks across three domains with a total of 560 injection cases. Here the agent has to continue planning as it uncovers information, since the set of legitimate actions is not known from the initial task alone. Lastly, *AutoDojo* extends three of the four AgentDojo suites (389 injection cases) with an adaptive attacker that uses an LLM to rewrite each injection over six rounds to bypass the defense. This attacker is weaker than the one we assume in Section II as it is black-box and can only observe whether an attack succeeds. So its results are a lower bound on adaptive attack success.

Baselines. We compare KAIROS against defenses at three levels: the prompt, the model, and the agent framework.

Prompt-level defenses only change what the agent reads. Spotlighting [12] marks untrusted content as data, and prompt sandwiching [49] repeats the user's task after it. *Model-level* defenses use a separate model to detect injected instructions in tool outputs before they reach the agent. We compare against the PI detector [50], a fine-tuned classifier that all three benchmarks report. *Framework-level* defenses restrict which actions the agent can take. Progent [16] enforces a tool-call policy that a language model derives from the task, and CaMeL [14] executes a program generated from the task under information-flow policies. We run CaMeL with its security policies enforced and use GPT-4.1 as the auxiliary model for Progent, the same model as KAIROS's oracle. Lastly, on AgentDojo we run all defenses in our own harness, while on AgentDyn and AutoDojo we report the values published with each benchmark.

Models and harness. Unless otherwise specified, the agent is GPT-4.1[1] at temperature zero with a concise, task-neutral system prompt. On AgentDyn and AutoDojo, we use the agent models of their original evaluations, GPT-4o and GPT-4o-mini respectively, so that our results are comparable to originally reported values. On AgentDojo, we additionally evaluate Qwen3.6-35B[2] and Llama-3.3-70B[3] as agents. Each benchmark defines the task through the user prompt and scores its completion. All defenses run without human intervention, so a blocked action never receives a user's approval as a fallback and each configuration is run once.

KAIROS integration. As the benchmarks simulate tools as in-memory objects, there is no isolation boundary to mediate for KAIROS. We therefore replace the benchmark's tool executor with an adapter that turns each simulated tool call into an outgoing event and its result into an incoming one, and add one hook after the model's turn that resolves an open scope when the agent finishes. Policy, provenance tracking, the speculative

[1] gpt-4.1-2025-04-14
[2] Qwen/Qwen3.6-35B-A3B
[3] meta-llama/Llama-3.3-70B-Instruct

TABLE I
COMPARISON OF DEFENSES ON AGENTDOJO WITH THREE AGENT MODELS (%).

		GPT-4.1				Qwen3.6-35B				Llama-3.3-70B			
Level	**Defense**	**ASR↓**	**U↑**	**U_b↑**	**NRP↑**	**ASR↓**	**U↑**	**U_b↑**	**NRP↑**	**ASR↓**	**U↑**	**U_b↑**	**NRP↑**
–	No defense	47.0	59.8	82.7	43.8	28.3	72.0	87.0	62.4	32.3	24.6	29.8	20.2
Model	PI detector [36]	9.5	24.0	40.1	36.3	2.9	29.8	50.5	49.0	4.0	17.0	20.1	19.3
Prompt	Prompt sandwiching [36]	44.6	63.7	**87.6**	48.5	14.4	**77.1**	**86.3**	73.9	22.5	26.9	30.8	23.9
	Spotlighting [12]	49.2	54.2	81.7	41.5	30.8	69.7	83.8	58.0	28.7	23.9	**38.0**	27.1
Framework	Progent [16]	11.5	57.6	78.2	69.2	5.4	70.2	82.1	77.7	8.0	32.0	31.8	29.3
	CaMeL [14]	**0.2**	40.7	38.0	37.9	**0.4**	37.0	40.4	40.2	**0.0**	26.0	26.5	26.5
System	KAIROS	2.7	**69.5**	85.1	**82.8**	1.3	76.5	84.6	**83.5**	2.4	**34.0**	32.3	**31.5**

ASR: attack success rate; U: utility under attack; U_b: benign utility; NRP: net resilient performance (Section IV-A).

state machine, and the oracle run on these events unchanged. Only the messages that carry a stub or an abort notice back to the agent are produced by the adapter. However, the events differ, for a simulated tool call names its tool and arguments, whereas the deployed boundary observes file operations and requests. The policy therefore declares, for each tool, whether it is reversible and which argument names its destination. The policies declare no refusing rule, as such a rule encodes knowledge of an attack and blocks it by construction, so the attack success we report would reflect our foresight rather than the monitor. In a deployment, such rules are what bounds the oracle, as no decision of the oracle can release an effect a rule refuses. Unless otherwise specified, the oracle is GPT-4.1 and decides each deferred effect against the user's task.

Metrics. We evaluate each defense by its *attack success rate* (ASR), defined as the percentage of injection cases in which the agent completes the attacker's goal. Compared against the undefended agent's ASR, this shows how many attacks a defense prevents. To capture the cost to the agent's usefulness, we measure its *benign utility* U_b, the percentage of user tasks completed when no attack is present, and its *utility under attack* U, the percentage of user tasks completed in the injection cases. To quantify the trade-off between security and utility, we report the *net resilient performance* (NRP) proposed by Zhang *et al.* [35] as the main metric:

$$\mathrm{NRP} = U_b \times (1 - \mathrm{ASR}).$$

B. Effectiveness

AgentDojo. With GPT-4.1 as the agent, KAIROS reaches the highest NRP of all defenses, 82.8 against 69.2 for Progent, the second best defense (Table I). It reduces attack success from 47.0% to 2.7%, with no successful attack in the Banking and Workspace suites, while its benign utility of 85.1% matches that of the undefended agent (82.7%). Utility under attack rises from 59.8% to 69.5%, the highest of all defenses. The other defenses trade one for the other: prompt-level defenses preserve utility but barely reduce attack success, whereas the model-level detector and CaMeL reduce attack success but complete fewer than half of the benign tasks. The picture holds for the two open-weight agents, with the oracle still GPT-4.1: KAIROS reduces attack success from 28.3% to 1.3% for Qwen3.6-35B and from 32.3% to 2.4% for Llama-3.3-70B. With both agents, KAIROS again reaches the highest NRP (83.5 and 31.5), with benign utility close to that of the undefended agent (84.6% against 87.0% for Qwen3.6-35B, 32.3% against 29.8% for Llama-3.3-70B). Notably, Llama completes few tasks even without a defense, so its utility is low throughout. An undefended agent that follows an injection often abandons the user's task and when KAIROS refuses the injected effect, it notifies the agent that the effect was not executed, that the remainder of the user's request remains valid, and instructs the agent to proceed. This recovers some utility.

AgentDyn. On open-ended tasks (Table II), KAIROS reduces attack success to 1.7%, against 37.8% reported for the undefended agent, and achieves the highest NRP (50.8 against 43.6 for prompt sandwiching). The other defenses diverge further than on AgentDojo. Prompt-level defenses keep their utility but reduce the ASR by at most 10.2 points compared to the undefended agent. The PI detector and Progent reach similarly low attack success, but complete almost no tasks under attack (0.6% and 5.8%). CaMeL is excluded here as it fixes its program before the task begins. KAIROS keeps its benign utility close to that of the undefended agent (51.7% against 53.3%), but open-ended tasks come at a cost in utility under attack (37.1% against 55.5%). This cost stems from held effects that later steps depend on, and it grows with each hold a task has to continue past. Tasks that continue past a single held effect retain 90% of their utility, while those that continue past two or more retain 62%. This is discussed further in Section V.

AutoDojo. KAIROS remains effective against an adaptive attacker where injections optimized against it succeed in 8.8% of the cases, compared to 52.4% without a defense (Table III). Together with Progent, it retains the highest NRP, as both keep attack success in single digits without giving up clean utility. Prompt-level defenses leave between 36% and 47% of the attacks successful, and the PI detector reduces attack success only to 15.4% while completing fewer than half of the clean tasks. The attacks that still succeed target tasks that delegate authority to a document, which the oracle reads as authorized

TABLE II
COMPARISON OF DEFENSES ON AGENTDYN WITH GPT-4O AS THE AGENT (%).

Level	Defense	ASR↓	U↑	U_b↑	NRP↑
–	No defense†	37.8	55.5	53.3	33.2
Model	PI detector†	**0.9**	0.6	0.0	0.0
Prompt	Prompt sandwiching†	31.2	**56.1**	**63.3**	43.6
	Spotlighting [12]†	27.6	52.2	55.0	39.8
Framework	Progent [16]†	1.7	5.8	6.7	6.6
System	KAIROS	1.7	37.1	51.7	**50.8**

† Reported by AgentDyn.

TABLE III
COMPARISON OF DEFENSES ON AUTODOJO WITH GPT-4O-MINI AS THE AGENT (%).

Level	Defense	ASR↓	U_b↑	NRP↑
–	No defense†	52.4	66.7	31.7
Model	PI detector†	15.4	47.4	40.1
Prompt	Prompt sandwiching†	36.3	59.6	38.0
	Spotlighting [12]†	46.8	59.6	31.7
Framework	Progent [16]†	**7.7**	63.2	58.3
System	KAIROS	8.8	**65.3**	**59.6**

† Reported by AutoDojo.

by the user.

C. Policy and Oracle Decisions

The design bounds the oracle to the effects the policy defers (Section III-C), so how much of the monitor's behavior rests on the oracle depends on how often the policy defers. As the policy decides without a model call, this share also determines the token and latency overhead of KAIROS (Section IV-E). We therefore examine which component decides the effects of a run, and how the oracle decides the effects that reach it. Figure 5 shows where the effects of the AgentDojo evaluation (Table I) with GPT-4.1 are decided. The policy directly releases most of the effects, 83% of the benign effects and 72% under attack, so only a minority ever reaches the oracle. In the benign runs, the oracle releases all but one effect it decides, the single refusal is the only false positive. Under attack, the policy defers more effects, and the oracle refuses more than half of them. Most deferrals stem from values in an effect whose provenance the policy cannot trace to a trusted source.

D. Oracle and Model Choice

Strict monitor. To measure what deferral and the oracle contribute, we disable both, so that every effect the policy defers is refused. This is the strict monitor that an oracle refusing everything would yield (Section III-C). Its attack success stays within the variation of a single run, so trusting the oracle costs no measurable security on AgentDojo. Its benign utility, however, halves from 85.1% to 42.7%, and its utility under attack drops from 69.5% to 34.7%. The policy thus provides the security, while deferral and the oracle together recover the utility that a strict monitor gives up.

Agent and oracle models. To distinguish the roles of the two models, the agent and the oracle are varied independently across three sizes within the Qwen3.5 family on the AgentDojo Banking suite (Table IV). When the oracle is fixed, the 9B agent consistently achieves the lowest NRP across all oracles (68.8 to 81.2). However, all pairings remain 18.0 to 52.4 points above the undefended agent. When the agent is fixed, a 9B oracle reduces NRP by 10.7 to 12.5 points for the 27B and 9B agents, but not for the 35B agent. The 35B and 27B oracles perform similarly, differing by no more than 1.7 points. When the agent and oracle are the same model, NRP ranges from 93.1 for the 27B model to 68.8 for the smallest. Therefore, deployment does not require the strongest model as the oracle. A mid-sized oracle is sufficient, while a weaker agent consistently lowers NRP across all oracles.

E. Cost

Because the policy decides without a model call, the token overhead, which is 17.7% on benign runs and 33.6% under attack, corresponds to the number of deferrals and is fully attributable to oracle calls. For comparison, CaMeL reports approximately 2.8 times the input and 2.7 times the output tokens of a single-mode agent [14], while AttriGuard incurs about twice the tokens and three times the latency [18].

The isolation mechanism introduces only a manageable overhead. Across 200 cycles of create, write, fsync, read, and unlink operations on 4 KB files, repeated three times, the filesystem channel adds an average of 9.62 ms per cycle or approximately 1.9 ms per operation. For 50 allowed requests, the proxy adds an average of 1.15 ms per request. Compared to the agent's model inference latency per step [51], this overhead is negligible.

V. DISCUSSION AND LIMITATIONS

KAIROS guarantees confinement for any agent and any oracle, whereas authorization depends on both the policy and the oracle and can only be measured (Section II). The evaluation attributes the measured security to the policy (Section IV-D), which is expected, because an injection that introduces its own value, such as a recipient or a URL, fails the integrity check unless its value matches a trusted one. The oracle determines only what the policy has deferred. The limitations of both mechanisms are discussed below.

Semantic gap. At the isolation boundary, the monitor observes file operations and requests instead of tool names and arguments. While this placement provides complete mediation (Section II), it introduces a semantic gap. A policy defined over tools can associate a rule with an operation and the role of each argument [16], [52], whereas a policy defined over events refers only to a path or destination and the values carried by an effect, and can thus express only a subset of these rules. Any rule that the policy cannot express must be

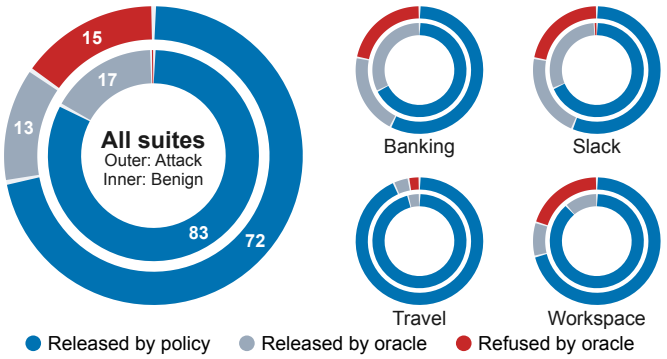

Fig. 5. Decisions per effect on AgentDojo (GPT-4.1, %).

TABLE IV
NRP WITH AGENT AND ORACLE MODELS VARIED INDEPENDENTLY (%, AGENTDOJO BANKING).

		Oracle		
Agent	**None**	**35B**	**27B**	**9B**
Qwen3.5-35B	62.6	86.3	87.5	92.5
Qwen3.5-27B	40.7	93.1	93.1	80.6
Qwen3.5-9B	50.8	79.5	81.2	68.8

Qwen3.5-35B-A3B (mixture-of-experts). None: the undefended agent.

deferred, so the oracle has to recover it from the task and the ordered trace. Existing benchmarks expose every action as a named tool call, to our adapter as well (Section IV-A), and none composes an attack from individually legitimate steps, so measuring this class of defense requires a benchmark in which actions correspond to actual system effects.

Provenance precision. Any defense that permits untrusted content to reach a model must contend with the inability to precisely track data flow through inference. KAIROS considers a broader black box approach, encompassing the model, its framework, and associated tools, and therefore shares this limitation with existing defenses. Provenance is re-established by matching values at the isolation boundary (Section III-D). If an attacker's value is byte-identical to a trusted value, it is assigned the same provenance. In contrast, if the agent transforms a value, it is no longer recognized, which is why the threat model excludes deliberate transformation (Section II). Similarly, sensitivity declared for an object, such as a file path, does not persist if the agent moves the data to another object before reading it. Propagating the labels of all data read by the agent to every subsequent effect would maintain soundness but would defer nearly all effects after the first untrusted read. Label propagation within the agent [15] provides greater precision by tracking each value through the framework into and out of the model's context at the cost of modifying the agent.

Decision oracle vulnerability. The attacker can influence the oracle solely through its view, which must present the untrusted content underlying a deferred effect as evidence. While this design constrains the attack channel as each span carries its provenance, the content under review may still attempt to persuade the oracle, particularly when the task delegates authority to a document and the oracle interprets the document's instructions as those of the principal, which enables the remaining adaptive attacks to succeed (Section IV-B). An attacker familiar with the oracle and its view operates through the same channel, as it controls neither the task nor the policy and can, at most, cause a deferred effect to be released. Nevertheless, such an attacker can optimize content against the oracle more effectively than a black-box attacker [53], so these results do not bound the attacker's success rate. This limitation is inherent to any approach that interprets untrusted content to decide, and is independent of the present design. Reducing the capacity of the channel between the attacker and the oracle by, for example, only allowing untrusted content as restricted typed data [54] is likely to reduce but not mitigate the attack vector entirely.

Repeated deferral.

Deferral is essential for preserving utility and, consequently, the monitor's usability, especially during extended sessions where repeated application leads to cumulative costs. When the oracle releases an effect, it declassifies only that specific effect and retains the original labels of its associated values. As a result, any subsequent effect involving the same untrusted value is subject to repeated deferral. As untrusted content increases, deferrals occur more frequently, each withholding an effect that subsequent steps may require, and each decision is made based on an increasingly long trace. This process contributes to utility loss in open-ended tasks (Section IV-B). Partitioning the trace according to provenance would restrict a deferral to the effects within a single lineage, providing the oracle with a shorter and more pertinent trace. In this scenario, a release could apply to subsequent effects of the same lineage directed toward the same destination, albeit at the expense of a less granular declassification. Both approaches require a formal definition of when two values share a lineage, which string matching alone cannot provide.

Applicability. While we evaluate KAIROS on a relatively narrow scope of injection cases following the established benchmarks, the conceptual applicability of this architecture is much broader. Firstly, because every effect crosses the monitor before it is released, the boundary also yields a complete record of the agent's effects and of each decision with its justification. Additionally the oracle provides a point at which a human can intervene before an effect becomes irreversible. This directly supports the record-keeping and human-oversight obligations that the EU AI Act places on high-risk systems (Art. 12 and 14) [55], although compliance depends on the deployment as a whole.

Beyond observation, the guarantees of confinement do not depend on why the agent emits a malicious effect. They hold equally when an effect stems from an injection, a misaligned or backdoored model, a poisoned tool, or a plain mistake, as the

threat model already treats the agent as potentially fully adversarial (Section II-B). This matters beyond injection attacks, as recent incidents show agents compromising infrastructure far outside their task [3], [4]. Authorization generalizes partially, as the policy judges where the values of an effect come from and not who introduced them, so an effect steered by a value that no trusted source provides is deferred whether an injection or the agent itself produced it. However, scenarios that consider, for example, a misaligned model need to account for values the model deliberately transforms to hide their origin, which our authorization assumptions exclude due to the limits of provenance tracking discussed above (Section II).

VI. Related Work

We categorize prior work based on the enforcement level and the capabilities enabled at each point.

Prompt- and model-level defenses. Prompt- and model-level defenses either mark or separate untrusted content at inference time [12], or encode an ordering of instruction sources into the model weights [13]. Guardrail middleware filters both incoming and outgoing content [56], while detectors classify injected text before it reaches the agent [17]. These defenses operate solely on text and do not observe the agent's impact on the system. On AgentDojo, they either maintain the attack rate near the undefended baseline or disable the agent entirely. LlamaFirewall's AlignmentCheck [17] audits the agent's trace against the user's goal and is most similar to the oracle described here. However, it evaluates without provenance and lacks the ability to hold or reverse actions.

Framework-level defenses. Structural defenses primarily enforce policies at the agent's tool dispatch layer. CaMeL, for example, separates a privileged planner from a quarantined model to prevent untrusted data from influencing control flow [14]. Another approach propagates information-flow labels through the planner or through inter-agent communication [15], [57]. Propagating labels through the planner's context is sound within the label algebra and can detect decision-influence attacks that are outside the present threat model, but this method often results in significant over-tainting. Once the planner accesses untrusted content, all subsequent actions inherit its label, leading to denial of actions even when they are part of the intended task, such as appending a fetched paper's summary to a local file. Privilege-based defenses restrict the calls an agent may make, with policies over tool names and arguments written in a domain-specific language [52], derived from the task by an LLM and refined during execution, with any expansion left to user discretion [16]. Alternatively, policies may be expressed as Datalog rules over a causal dependency graph of the agent's actions [58] and generalized to probabilistic predicates with a sound bound on violation probability [59]. Attribution-based defenses verify whether a call was proposed due to injected data. AgentArmor constructs a program-dependence graph from the trace and performs type checking [60], while AttriGuard re-executes the agent's model on a modified history in which an LLM rewrites untrusted observations from commands into third-person reports, blocking the call if the replay no longer proposes it [18]. These mechanisms provide more detailed per-call semantics than KAIROS, but they rely on agent cooperation, whether through a replaced planner, an instrumented framework, or control over the inference loop. As a result, their coverage is limited to the declared tool interface. FORGE, for example, excludes raw sockets, standard I/O, and shell effects from its mediation, and its probabilistic generalization deems agents' ad-hoc scripts impossible to model in advance [59]. Additionally, most of these defenses permit or deny actions at the time of the call, which means that actions influenced by untrusted content are refused even when they are required by the task. Progent's approval step is an exception, but in the absence of human intervention, it also results in denial. Enforcement at the tool interface and KAIROS are therefore complementary, since the former provides rich semantics with interface-relative coverage, while the latter ensures complete coverage at the isolation boundary, with semantics reconstructed at resolution.

Transactions and rollback. Transactional runtimes aggregate the tool calls of a task into a unit, maintaining reversible mutations in a shadow state while external effects are staged until the unit is validated [61]. Each effect is settled based on whether it can be buffered, compensated, or cannot be undone [62], or workflows are structured as stages with compensating steps [63]. Recovery-oriented systems, by contrast, reverse effects after they occur, using snapshots taken before commands of uncertain effect [64], per-tool compensation actions [65], or checkpoints and branches of the framework's state [66]. The primary distinction between these approaches and KAIROS lies in the transaction boundary and the commit decision process. Runtimes and recovery systems interpose at tool dispatch or within the framework, so effects produced outside the declared interface are not included in the transaction. Generally, commits are based on progress, failure, or operator decision, rather than on the provenance of values. KAIROS instead places the transaction boundary at the isolation boundary and lets provenance and the oracle's decision on the ordered trace determine the commit.

Isolation and system-level monitoring. Recent research suggests that agents should be secured similarly to other systems, treating the model as an untrusted component and enforcing invariants at the system level [20]. Observability tools already monitor agents at this level. AgentSight, for example, traces system calls and encrypted traffic using eBPF, enabling an observer model to correlate the agent's LLM traffic with its system activity [21]. This tool detects rather than enforces, and its visibility into encrypted traffic depends on hooks into a specific TLS library. General runtime security monitors and agent telemetry platforms record events without agent semantics or enforcement [67], [68]. Isolation is provided by user-space kernels, microVMs, and hosted agent sandboxes [24], [25], [69]–[71]. These mechanisms protect the host from the agent, but the attacks under consideration remain within the scope authorized by the sandbox, as an injected

agent misuses only the files and network access granted to it. KAIROS leverages the same isolation mechanisms and introduces additional mediation.

Information-flow. The labeling approach in this work follows Denning's lattice model [44]. Operating system-level information-flow control enforces labels on processes managed by the kernel [72], [73], and dynamic taint tracking monitors data through code that does not cooperate [38], [74]. TaintDroid is the most closely related system, but it instruments the runtime it tracks [38]. In contrast, KAIROS observes only the input and output of a component whose internals it cannot inspect, resulting in labels that are approximate by design.

VII. CONCLUSION

Providing adequate isolation and authorization mechanisms for LLM agents becomes increasingly important as the capabilities and autonomy of widely deployed agents continue to grow. With KAIROS, we combine system-level isolation with a monitor that authorizes each effect of the agent at the isolation boundary. Since every effect of an unmodified agent crosses this interface, whether it stems from a tool call or from a script the agent wrote, complete mediation becomes a property of the isolation layer rather than of the agent's cooperation. Authorization rests on a declarative policy, which releases an effect when the values that steer it stem from a trusted source, such as the principal's task. Additionally, the monitor can hold effects on both the file and the network channel, so that it can defer the decision on an effect the policy cannot vouch for while the agent continues speculatively. Before such an effect becomes irreversible, a decision oracle, instantiated in our evaluation as a language model, decides whether to release or refuse it based on the agent's trace. We show that KAIROS achieves the highest net resilient performance among evaluated defenses across three benchmarks and three agent models. This results from combining the security provided by the policy with the utility recovered by letting the oracle decide deferred effects later, when more of the trace is available. These results highlight that the trade-off between security and utility commonly reported for agent defenses can be improved through deferral and speculative execution. Overall, while we evaluate KAIROS on common prompt injection benchmarks, confinement at the boundary holds regardless of why an agent emits an effect, and we see such a monitor as a foundation for overseeing increasingly autonomous agents beyond prompt injection.

VIII. OPEN SCIENCE

The source code of KAIROS, including all components, is available at https://github.com/UzL-ITS/Kairos. The commercial coding agent utilized in the deployed stack is closed-source and therefore not included. Because the evaluation relies on hosted models that providers may alter or discontinue, the released logs enable verification of the reported results without the need for re-execution.

IX. LLM USAGE CONSIDERATIONS

Large language models are central to this study. They function as agents under test, as the decision oracle, and, in the adaptive study, as the attacker (Section IV). Their use is therefore inherent to the research question, and we did not train models or collect data from human subjects. The primary experiments employ open-weight and commercial models, accessed via OpenRouter under fixed model identifiers. Because providers may update the models behind these identifiers, results may not be exactly reproducible, so we release all logs with our artifact. To limit the volume of queries, we reuse results reported by prior work where the setup matches, as marked in Section IV. During the development of this paper, we used LLMs for coding assistance. LLMs were used for editorial purposes in this manuscript, and all outputs were inspected by the authors to ensure accuracy and originality. The ideas and results presented in this work are solely those of the authors.

ACKNOWLEDGMENTS

This work was funded by the German Federal Ministry of Research, Technology and Space (BMFTR) through the projects AnoMed-II and AnoMed-KI. Lorenzo Cavallaro was partially supported by a Google Academics Research Award.

REFERENCES

[1] M. McCain, T. Millar, S. Huang, J. Eaton, K. Handa, M. Stern, A. Tamkin, M. Kearney, E. Durmus, J. Shen, J. Hong, B. Calvert, J. S. Chan, F. Mosconi, D. Saunders, T. Neylon, G. Nicholas, S. Pollack, J. Clark, and D. Ganguli. (2026) Measuring ai agent autonomy in practice. [Online]. Available: https://anthropic.com/research/measuring-agent-autonomy

[2] B. Liu, H. Qiu, Í. Goiri, R. Fonseca, R. Bianchini, and E. Choukse, "Agentic coding in the wild: Characterizing github copilot traces at production scale," *CoRR*, vol. abs/2608.00101, 2026. [Online]. Available: https://doi.org/10.48550/arXiv.2608.00101

[3] Hugging Face, "Anatomy of a frontier lab agent intrusion: A technical timeline of the july 2026 incident," https://huggingface.co/blog/agent-intrusion-technical-timeline, 2026, accessed 2026-09-28.

[4] METR, "Brief independent investigation of agents' behavior, reasoning and collaboration in the OpenAI / Hugging Face hacking incident," https://metr.org/blog/2026-08-26-openai-hugging-face-incident-investigation/, Aug. 2026, accessed 2026-09-28.

[5] E. Zverev, S. Abdelnabi, M. Fritz, and C. H. Lampert, "Can llms separate instructions from data? and what do we even mean by that?" *CoRR*, vol. abs/2403.06833, 2024. [Online]. Available: https://doi.org/10.48550/arXiv.2403.06833

[6] S. Abdelnabi, K. Greshake, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world llm-integrated applications with indirect prompt injection," in *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security, AISec 2023, Copenhagen, Denmark, 30 November 2023*, M. Pintor, X. Chen, and F. Tramèr, Eds. ACM, 2023, pp. 79–90. [Online]. Available: https://doi.org/10.1145/3605764.3623985

[7] O. Brodt, E. Feldman, B. Schneier, and B. Nassi, "The promptware kill chain: How prompt injections gradually evolved into a multistep malware delivery mechanism," 2026. [Online]. Available: https://arxiv.org/abs/2601.09625

[8] K. Schulz, K. Yeung, and T. Bonner, "How hidden prompt injections can hijack AI code assistants like Cursor," HiddenLayer Research, Jul. 2025. [Online]. Available: https://www.hiddenlayer.com/research/how-hidden-prompt-injections-can-hijack-ai-code-assistants-like-cursor

[9] B. Nassi, S. Cohen, and O. Yair, "Invitation is all you need! promptware attacks against llm-powered assistants in production are practical and dangerous," *CoRR*, vol. abs/2508.12175, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2508.12175

[10] S. Cohen and J. Donato, "OpenClaw or OpenDoor? indirect prompt injection makes OpenClaw vulnerable to backdoors and much more," Zenity Labs, Feb. 2026, accessed 2026-09-29. [Online]. Available: https://labs.zenity.io/p/openclaw-or-opendoor-indirect-prompt-injection-makes-openclaw-vulnerable-to-backdoors-and-much-more

[11] S. Abdelnabi, A. Fay, A. Salem, E. Zverev, K. Liao, C. Liu, C. Kuo, J. Weigend, D. Manlangit, A. Apostolov, H. Umair, J. Donato, M. Kawakita, A. Mahboob, T. H. Bach, T. Chiang, M. Cho, H. Choi, B. Kim, H. Lee, B. Pannell, C. McCauley, M. Russinovich, A. Paverd, and G. Cherubin, "Llmail-inject: A dataset from a realistic adaptive prompt injection challenge," *CoRR*, vol. abs/2506.09956, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2506.09956

[12] K. Hines, G. Lopez, M. Hall, F. Zarfati, Y. Zunger, and E. Kiciman, "Defending against indirect prompt injection attacks with spotlighting," in *Proceedings of the Conference on Applied Machine Learning in Information Security (CAMLIS 2024), Arlington, Virginia, USA, October 24-25, 2024*, ser. CEUR Workshop Proceedings, R. Allen, S. Samtani, E. Raff, and E. M. Rudd, Eds., vol. 3920. CEUR-WS.org, 2024, pp. 48–62. [Online]. Available: https://ceur-ws.org/Vol-3920/paper03.pdf

[13] E. Wallace, K. Xiao, R. Leike, L. Weng, J. Heidecke, and A. Beutel, "The instruction hierarchy: Training llms to prioritize privileged instructions," *CoRR*, vol. abs/2404.13208, 2024. [Online]. Available: https://doi.org/10.48550/arXiv.2404.13208

[14] E. Debenedetti, I. Shumailov, T. Fan, J. Hayes, N. Carlini, D. Fabian, C. Kern, C. Shi, A. Terzis, and F. Tramèr, "Defeating prompt injections by design," *CoRR*, vol. abs/2503.18813, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2503.18813

[15] M. Costa, B. Köpf, A. Kolluri, A. Paverd, M. Russinovich, A. Salem, S. Tople, L. Wutschitz, and S. Zanella-Béguelin, "Securing AI agents with information-flow control," *CoRR*, vol. abs/2505.23643, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2505.23643

[16] T. Shi, J. He, Z. Wang, H. Li, L. Wu, W. Guo, and D. Song, "Progent: Securing ai agents with privilege control," 2026. [Online]. Available: https://arxiv.org/abs/2504.11703

[17] S. Chennabasappa, C. Nikolaidis, D. Song, D. Molnar, S. Ding, S. Wan, S. Whitman, L. Deason, N. Doucette, A. Montilla, A. Gampa, B. de Paola, D. Gabi, J. Crnkovich, J. Testud, K. He, R. Chaturvedi, W. Zhou, and J. Saxe, "Llamafirewall: An open source guardrail system for building secure AI agents," *CoRR*, vol. abs/2505.03574, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2505.03574

[18] Y. He, H. Zhu, Y. Li, S. Shao, H. Yao, Z. Liu, and Z. Qin, "AttriGuard: Defeating indirect prompt injection in LLM agents via causal attribution of tool invocations," in *35th USENIX Security Symposium (USENIX Security 26)*. Baltimore, MD: USENIX Association, Aug. 2026, pp. 1547–1566. [Online]. Available: https://www.usenix.org/conference/usenixsecurity26/presentation/he-yu

[19] J. P. Anderson, "Computer security technology planning study," Electronic Systems Division, Air Force Systems Command, Hanscom AFB, Bedford, MA, Tech. Rep. ESD-TR-73-51, Vols. I & II, 1972, the "Anderson Report"; DTIC AD-758 206. [Online]. Available: https://csrc.nist.gov/files/pubs/conference/1998/10/08/proceedings-of-the-21st-nissc-1998/final/docs/early-cs-papers/ande72a.pdf

[20] M. Christodorescu, E. Fernandes, A. Hooda, S. Jha, J. Rehberger, K. Chaudhuri, X. Fu, K. Shams, G. Amir, J. Choi, S. Choudhary, N. Palumbo, A. Labunets, and N. V. Pandya, "Agent security is a systems problem," *CoRR*, vol. abs/2605.18991, 2026. [Online]. Available: https://doi.org/10.48550/arXiv.2605.18991

[21] Y. Zheng, Y. Hu, T. Yu, and A. Quinn, "Agentsight: System-level observability for AI agents using ebpf," in *Proceedings of the 4th Workshop on Practical Adoption Challenges of ML for Systems, PACMI 2025, Seoul, Republic of Korea, October 13-16, 2025*. ACM, 2025, pp. 110–115. [Online]. Available: https://doi.org/10.1145/3766882.3767169

[22] H. Hu, P. Chen, Y. Zhao, and Y. Chen, "Agentsentinel: An end-to-end and real-time security defense framework for computer-use agents," in *Proceedings of the 2025 ACM SIGSAC Conference on Computer and Communications Security, CCS 2025, Taipei, Taiwan, October 13-17, 2025*, C. Huang, J. Chen, S. Shieh, D. Lie, and V. Cortier, Eds. ACM, 2025, pp. 3535–3549. [Online]. Available: https://doi.org/10.1145/3719027.3765064

[23] Y. Zheng, T. Wu, Q. Fu, T. Yu, W. Mao, T. Ma, D. Williams, W. Wang, and A. Quinn, "Actplane: Programmable os-level policy enforcement for agent harnesses," *CoRR*, vol. abs/2606.25189, 2026. [Online]. Available: https://doi.org/10.48550/arXiv.2606.25189

[24] E2B, "E2B," https://e2b.dev, 2026, firecracker-based microVM sandboxes for AI agents.

[25] Daytona, "Daytona," https://www.daytona.io, 2026, secure infrastructure for running AI-generated code.

[26] L. Staufer, K. Feng, K. Wei, L. Bailey, Y. Duan, M. Yang, A. P. Ozisik, S. Casper, and N. Kolt, "The 2025 AI agent index: Documenting technical and safety features of deployed agentic AI systems," in *Proceedings of the 2026 ACM Conference on Fairness, Accountability, and Transparency, FAccT 2026, Montreal, QC, Canada, June 25-28, 2026*. ACM, 2026, pp. 1536–1576. [Online]. Available: https://doi.org/10.1145/3805689.3806728

[27] N. Hardy, "The confused deputy (or why capabilities might have been invented)," *ACM SIGOPS Oper. Syst. Rev.*, vol. 22, no. 4, pp. 36–38, 1988. [Online]. Available: https://doi.org/10.1145/54289.871709

[28] F. B. Schneider, "Enforceable security policies," *ACM Trans. Inf. Syst. Secur.*, vol. 3, no. 1, pp. 30–50, 2000. [Online]. Available: https://doi.org/10.1145/353323.353382

[29] J. Ligatti, L. Bauer, and D. Walker, "Edit automata: enforcement mechanisms for run-time security policies," *Int. J. Inf. Sec.*, vol. 4, no. 1-2, pp. 2–16, 2005. [Online]. Available: https://doi.org/10.1007/s10207-004-0046-8

[30] E. B. Nightingale, P. M. Chen, and J. Flinn, "Speculative execution in a distributed file system," in *Proceedings of the 20th ACM Symposium on Operating Systems Principles 2005, SOSP 2005, Brighton, UK, October 23-26, 2005*, A. Herbert and K. P. Birman, Eds. ACM, 2005, pp. 191–205. [Online]. Available: https://doi.org/10.1145/1095810.1095829

[31] Cloud Hypervisor Project, "Cloud hypervisor," https://www.cloudhypervisor.org, 2026, open-source virtual machine monitor, Linux Foundation project.

[32] Linux Kernel Documentation, "Overlay filesystem," https://docs.kernel.org/filesystems/overlayfs.html, 2026, documentation/filesystems/overlayfs.rst.

[33] B. K. R. Vangoor, V. Tarasov, and E. Zadok, "To FUSE or not to FUSE: performance of user-space file systems," in *15th USENIX Conference on File and Storage Technologies, FAST 2017, Santa Clara, CA, USA, February 27 - March 2, 2017*, G. Kuenning and C. A. Waldspurger, Eds. USENIX Association, 2017, pp. 59–72. [Online]. Available: https://www.usenix.org/conference/fast17/technical-sessions/presentation/vangoor

[34] mitmproxy Project, "mitmproxy," https://www.mitmproxy.org, 2026, open-source interactive TLS-capable intercepting HTTP proxy.

[35] H. Zhang, J. Huang, K. Mei, Y. Yao, Z. Wang, C. Zhan, H. Wang, and Y. Zhang, "Agent security bench (ASB): formalizing and benchmarking attacks and defenses in llm-based agents," in *The Thirteenth International Conference on Learning Representations, ICLR 2025, Singapore, April 24-28, 2025*. OpenReview.net, 2025. [Online]. Available: https://openreview.net/forum?id=V4y0CpX4hK

[36] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr, "AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents," in *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*, 2024, arXiv:2406.13352. [Online]. Available: https://arxiv.org/abs/2406.13352

[37] B. W. Lampson, "A note on the confinement problem," *Commun. ACM*, vol. 16, no. 10, pp. 613–615, 1973. [Online]. Available: https://doi.org/10.1145/362375.362389

[38] W. Enck, P. Gilbert, S. Han, V. Tendulkar, B. Chun, L. P. Cox, J. Jung, P. D. McDaniel, and A. N. Sheth, "Taintdroid: An information-flow tracking system for realtime privacy monitoring on smartphones," *ACM Trans. Comput. Syst.*, vol. 32, no. 2, pp. 5:1–5:29, 2014. [Online]. Available: https://doi.org/10.1145/2619091

[39] R. Levin, E. S. Cohen, W. M. Corwin, F. J. Pollack, and W. A. Wulf, "Policy/mechanism separation in HYDRA," in *Proceedings of the Fifth Symposium on Operating System Principles, SOSP 1975, The University of Texas at Austin, Austin, Texas, USA, November 19-21, 1975*, J. C. Browne and J. Rodriguez-Rosell, Eds. ACM, 1975, pp. 132–140. [Online]. Available: https://doi.org/10.1145/800213.806531

[40] E. B. Nightingale, K. Veeraraghavan, P. M. Chen, and J. Flinn, "Rethink the sync," in *7th Symposium on Operating Systems Design and Implementation (OSDI '06), November 6-8, Seattle, WA, USA*, B. N. Bershad and J. C. Mogul, Eds. USENIX Association, 2006, pp. 1–14. [Online]. Available: http://www.usenix.org/events/osdi06/tech/nightingale.html

[41] K. J. Arrow and A. C. Fisher, "Environmental preservation, uncertainty, and irreversibility," *The Quarterly Journal of Economics*, vol. 88, no. 2, pp. 312–319, 1974. [Online]. Available: http://www.jstor.org/stable/1883074

[42] E. N. Elnozahy, L. Alvisi, Y. Wang, and D. B. Johnson, "A survey of rollback-recovery protocols in message-passing systems," *ACM Comput. Surv.*, vol. 34, no. 3, pp. 375–408, 2002. [Online]. Available: https://doi.org/10.1145/568522.568525

[43] H. T. Kung and J. T. Robinson, "On optimistic methods for concurrency control," *ACM Trans. Database Syst.*, vol. 6, no. 2, pp. 213–226, 1981. [Online]. Available: https://doi.org/10.1145/319566.319567

[44] D. E. Denning, "A lattice model of secure information flow," *Commun. ACM*, vol. 19, no. 5, pp. 236–243, 1976. [Online]. Available: https://doi.org/10.1145/360051.360056

[45] A. Sabelfeld and D. Sands, "Declassification: Dimensions and principles," *J. Comput. Secur.*, vol. 17, no. 5, pp. 517–548, 2009. [Online]. Available: https://doi.org/10.3233/JCS-2009-0352

[46] A. C. Myers, A. Sabelfeld, and S. Zdancewic, "Enforcing robust declassification and qualified robustness," *J. Comput. Secur.*, vol. 14, no. 2, pp. 157–196, 2006. [Online]. Available: https://doi.org/10.3233/jcs-2006-14203

[47] H. Li, R. Wen, S. Shi, N. Zhang, Y. Vorobeychik, and C. Xiao, "Agentdyn: Are your agent security defenses deployable in real-world dynamic environments?" 2026. [Online]. Available: https://arxiv.org/abs/2602.03117

[48] X. Ma, T. Li, C. Xiao, Z. Yu, N. Zhang, and Y. Vorobeychik, "Autodojo: Adaptive black-box attacks reveal the limits of IPI defenses and task-specification effects in LLM agents," *CoRR*, vol. abs/2606.15057, 2026. [Online]. Available: https://doi.org/10.48550/arXiv.2606.15057

[49] S. Schulhoff, "Sandwich defense," https://learnprompting.org/docs/prompt_hacking/defensive_measures/sandwich_defense, 2024, learn Prompting.

[50] ProtectAI.com, "Fine-tuned DeBERTa-v3-base for prompt injection detection," https://huggingface.co/ProtectAI/deberta-v3-base-prompt-injection-v2, 2024.

[51] OpenRouter, "OpenAI GPT-4.1 on OpenRouter," https://openrouter.ai/openai/gpt-4.1, 2026.

[52] H. Wang, C. M. Poskitt, and J. Sun, "Agentspec: Customizable runtime enforcement for safe and reliable LLM agents," *CoRR*, vol. abs/2503.18666, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2503.18666

[53] M. Nasr, N. Carlini, C. Sitawarin, S. V. Schulhoff, J. Hayes, M. Ilie, J. Pluto, S. Song, H. Chaudhari, I. Shumailov, A. Thakurta, K. Y. Xiao, A. Terzis, and F. Tramèr, "The attacker moves second: Stronger adaptive attacks bypass defenses against llm jailbreaks and prompt injections," *CoRR*, vol. abs/2510.09023, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2510.09023

[54] D. Jacob, E. Alghamdi, Z. Hu, B. Alomair, and D. Wagner, "Preventing prompt injection with type-directed privilege separation," 2026. [Online]. Available: https://arxiv.org/abs/2509.25926

[55] European Parliament and Council of the European Union, "Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 Laying Down Harmonised Rules on Artificial Intelligence (Artificial Intelligence Act)," https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng, 2024.

[56] T. Rebedea, R. Dinu, M. N. Sreedhar, C. Parisien, and J. Cohen, "Nemo guardrails: A toolkit for controllable and safe LLM applications with programmable rails," in *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing, EMNLP 2023 - System Demonstrations, Singapore, December 6-10, 2023*, Y. Feng and E. Lefever, Eds. Association for Computational Linguistics, 2023, pp. 431–445. [Online]. Available: https://doi.org/10.18653/v1/2023.emnlp-demo.40

[57] P. Li, X. Zou, Z. Wu, R. Li, S. Xing, H. Zheng, Z. Hu, Y. Wang, H. Li, Q. Yuan, Y. Zhang, and Z. Tu, "SAFEFLOW: A principled protocol for trustworthy and transactional autonomous agent systems," *CoRR*, vol. abs/2506.07564, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2506.07564

[58] N. Palumbo, S. Choudhary, J. Choi, G. Amir, P. Chalasani, and S. Jha, "Formal policy enforcement for real-world agentic systems," 2026. [Online]. Available: https://arxiv.org/abs/2602.16708

[59] A. Solko-Breslin, P. K. Mudrakarta, M. Christodorescu, S. Jha, and K. D. Dvijotham, "Efficient and sound probabilistic verification for AI agents," *CoRR*, vol. abs/2606.20510, 2026. [Online]. Available: https://doi.org/10.48550/arXiv.2606.20510

[60] P. Wang, Y. Liu, Y. Lu, Y. Cai, H. Chen, Q. Yang, J. Zhang, J. Hong, and Y. Wu, "Agentarmor: Enforcing program analysis on agent runtime trace to defend against prompt injection," *CoRR*, vol. abs/2508.01249, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2508.01249

[61] Z. Chen, H. Liu, D. Xu, D. Dong, J. Li, B. Pu, and J. Zhai, "Cordon: Semantic transactions for tool-using LLM agents," *CoRR*, vol. abs/2606.17573, 2026. [Online]. Available: https://doi.org/10.48550/arXiv.2606.17573

[62] B. Mohammadi, N. Potamitis, L. H. Klein, A. Arora, and L. Bindschaedler, "Atomix: Timely, transactional tool use for reliable agentic workflows," *CoRR*, vol. abs/2602.14849, 2026. [Online]. Available: https://doi.org/10.48550/arXiv.2602.14849

[63] E. Y. Chang and L. Geng, "Sagallm: Context management, validation, and transaction guarantees for multi-agent LLM planning," *Proc. VLDB Endow.*, vol. 18, no. 12, pp. 4874–4886, 2025. [Online]. Available: https://www.vldb.org/pvldb/vol18/p4874-chang.pdf

[64] B. Yan, "Fault-tolerant sandboxing for AI coding agents: A transactional approach to safe autonomous execution," *CoRR*, vol. abs/2512.12806, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2512.12806

[65] S. G. Patil, T. Zhang, V. Fang, N. C., R. Huang, A. Hao, M. Casado, J. E. Gonzalez, R. A. Popa, and I. Stoica, "Goex: Perspectives and designs towards a runtime for autonomous LLM applications," *CoRR*, vol. abs/2404.06921, 2024. [Online]. Available: https://doi.org/10.48550/arXiv.2404.06921

[66] Y. Li, S. Ping, X. Chen, X. Qi, Z. Wang, Y. Luo, and X. Zhang, "Agentgit: A version control framework for reliable and scalable llm-powered multi-agent systems," *CoRR*, vol. abs/2511.00628, 2025. [Online]. Available: https://doi.org/10.48550/arXiv.2511.00628

[67] The Falco Authors, "Falco," https://falco.org, 2026.

[68] LangChain, "LangSmith," https://www.langchain.com/langsmith, 2026.

[69] Google, "gVisor," https://gvisor.dev, 2026.

[70] A. Agache, M. Brooker, A. Iordache, A. Liguori, R. Neugebauer, P. Piwonka, and D. Popa, "Firecracker: Lightweight virtualization for serverless applications," in *17th USENIX Symposium on Networked Systems Design and Implementation, NSDI 2020, Santa Clara, CA, USA, February 25-27, 2020*, R. Bhagwan and G. Porter, Eds. USENIX Association, 2020, pp. 419–434. [Online]. Available: https://www.usenix.org/conference/nsdi20/presentation/agache

[71] D. Huynh, "LLM Sandbox," https://github.com/vndee/llm-sandbox, 2026.

[72] N. Zeldovich, S. Boyd-Wickizer, E. Kohler, and D. Mazières, "Making information flow explicit in histar," in *7th Symposium on Operating Systems Design and Implementation (OSDI '06), November 6-8, Seattle, WA, USA*, B. N. Bershad and J. C. Mogul, Eds. USENIX Association, 2006, pp. 263–278. [Online]. Available: http://www.usenix.org/events/osdi06/tech/zeldovich.html

[73] M. N. Krohn, A. Yip, M. Z. Brodsky, N. Cliffer, M. F. Kaashoek, E. Kohler, and R. Morris, "Information flow control for standard OS abstractions," in *Proceedings of the 21st ACM Symposium on Operating Systems Principles 2007, SOSP 2007, Stevenson, Washington, USA, October 14-17, 2007*, T. C. Bressoud and M. F. Kaashoek, Eds. ACM, 2007, pp. 321–334. [Online]. Available: https://doi.org/10.1145/1294261.1294293

[74] J. Newsome and D. Song, "Dynamic taint analysis for automatic detection, analysis, and signature generation of exploits on commodity software," in *Proceedings of the 12th Annual Network and Distributed System Security Symposium (NDSS)*. The Internet Society, Feb. 2005. [Online]. Available: https://www.ndss-symposium.org/wp-content/uploads/2017/09/Dynamic-Taint-Analysis-for-Automatic-Detection-Analysis-and-SignatureGeneration-of-Exploits-on-Commodity-Software-Dawn-Song.pdf

APPENDIX A
ADDITIONAL DETAILS

A. Per-Suite Results on AgentDojo

This appendix presents a detailed breakdown of AgentDojo results from Section IV by suite. Table V displays attack success, utility under attack, and benign utility per suite for

TABLE V
AGENTDOJO PER SUITE FOR THE THREE AGENTS (%). COLUMNS AS IN TABLE I; MEANS ARE UNWEIGHTED OVER THE FOUR SUITES.

		Banking		Slack		Travel		Workspace		Mean			
Level	**Defense**	ASR	U	ASR	U	ASR	U	ASR	U	ASR	U	U_b	NRP
GPT-4.1													
–	No defense	43.1	83.3	88.6	60.0	21.4	67.9	35.0	27.9	47.0	59.8	82.7	43.8
Model	PI detector	3.5	30.6	16.2	30.5	**0.0**	13.6	18.3	21.2	9.5	24.0	40.1	36.3
Prompt	Prompt sandwiching	36.8	**86.1**	74.3	**62.9**	37.1	62.1	30.0	43.8	44.6	63.7	**87.6**	48.5
	Spotlighting	45.1	79.2	81.9	54.3	28.6	58.6	41.2	24.6	49.2	54.2	81.7	41.5
Framework	Progent	9.7	72.2	7.6	44.8	17.9	71.4	10.8	42.1	11.5	57.6	78.2	69.2
	CaMeL	**0.0**	36.1	**1.0**	39.0	**0.0**	33.6	**0.0**	54.2	**0.2**	40.7	38.0	37.9
System	KAIROS	**0.0**	82.6	2.9	61.0	7.9	**74.3**	**0.0**	**60.0**	2.7	**69.5**	85.1	**82.8**
Qwen3.6-35B													
–	No defense	27.8	77.8	64.8	69.5	15.0	64.3	5.8	76.2	28.3	72.0	87.0	62.4
Model	PI detector	**0.0**	36.8	6.7	33.3	**0.0**	3.6	5.0	45.4	2.9	29.8	50.5	49.0
Prompt	Prompt sandwiching	17.4	76.4	36.2	66.7	2.1	**87.1**	2.1	78.3	14.4	**77.1**	**86.3**	73.9
	Spotlighting	35.4	77.8	58.1	**70.5**	20.0	58.6	9.6	72.1	30.8	69.7	83.8	58.0
Framework	Progent	8.3	74.3	5.7	61.9	4.3	80.0	3.3	64.6	5.4	70.2	82.1	77.7
	CaMeL	**0.0**	36.1	**0.0**	20.0	1.4	42.9	**0.0**	49.2	**0.4**	37.0	40.4	40.2
System	KAIROS	0.7	**78.5**	3.8	65.7	0.7	76.4	**0.0**	**85.4**	1.3	76.5	84.6	**83.5**
Llama-3.3-70B													
–	No defense	34.7	38.2	40.0	26.7	35.7	20.7	18.8	12.9	32.3	24.6	29.8	20.2
Model	PI detector	6.9	30.6	2.9	24.8	**0.0**	5.0	6.2	7.5	4.0	17.0	20.1	19.3
Prompt	Prompt sandwiching	37.5	**42.4**	21.9	22.9	17.1	29.3	13.3	12.9	22.5	26.9	30.8	23.9
	Spotlighting	27.1	39.6	39.0	23.8	33.6	23.6	15.0	8.8	28.7	23.9	**38.0**	27.1
Framework	Progent	6.9	**42.4**	10.5	**31.4**	8.6	32.9	5.8	21.2	8.0	32.0	31.8	29.3
	CaMeL	**0.0**	38.2	**0.0**	21.9	**0.0**	0.7	**0.0**	**43.3**	**0.0**	26.0	26.5	26.5
System	KAIROS	**0.0**	40.3	3.8	29.5	5.7	**38.6**	**0.0**	27.5	2.4	**34.0**	32.3	**31.5**

The KAIROS oracle and Progent's policy model are GPT-4.1 for every agent. CaMeL runs with its security policies enforced, and its privileged and quarantined models are the agent model of each block.

TABLE VI
AGENT AND ORACLE MODELS VARIED INDEPENDENTLY (%, AGENTDOJO BANKING).

Agent	**Oracle**	**ASR↓**	**U↑**	**U_b↑**	**NRP↑**
Qwen3.5-35B	None	22.9	78.5	81.2	62.6
	Qwen3.5-35B	1.4	77.1	87.5	86.3
	Qwen3.5-27B	0.0	80.6	87.5	87.5
	Qwen3.5-9B	1.4	79.2	93.8	92.5
Qwen3.5-27B	None	53.5	75.7	87.5	40.7
	Qwen3.5-35B	0.7	85.4	93.8	93.1
	Qwen3.5-27B	0.7	73.6	93.8	93.1
	Qwen3.5-9B	0.7	77.8	81.2	80.6
Qwen3.5-9B	None	37.5	68.1	81.2	50.8
	Qwen3.5-35B	2.1	68.8	81.2	79.5
	Qwen3.5-27B	0.0	71.5	81.2	81.2
	Qwen3.5-9B	0.0	61.8	68.8	68.8

None: the undefended agent. Qwen3.5-35B is the mixture-of-experts model Qwen3.5-35B-A3B (3B active parameters).

each defense and all three agent models, using GPT-4.1 as the oracle. The mean columns correspond to Table I.

B. Agent and Oracle Model Pairings

Table VI presents the complete results underlying Table IV, including attack success, utility under attack, benign utility, and NRP for each agent and oracle model pairing, as well as the undefended agent. All pairings were evaluated using the AgentDojo Banking suite.